SerapHim | Independent Cyber Threat Intelligence

TLP:CLEAR | RESTRICTED DISTRIBUTION

CYBER THREAT INTELLIGENCE REPORT

FamousSparrow / SparrowDoor

Secondary Analysis of the Modular Variant (2024) with Analytical Continuation of CTI-003

Field	Value
Report ID	CTI-004 | SparrowDoor Modular
Report Date	March 29, 2026
Analyst	SerapHim
Analyst Role	Independent Cyber Threat Intelligence
Continues From	CTI-003 | SparrowDoor (March 16, 2026)
Threat Actor	FamousSparrow / Salt Typhoon / Earth Estries
Attribution	PRC HIGH confidence (external reporting)
Malware Family	SparrowDoor Modular Variant (2024)
Sample Source	No sample available secondary analysis only
Primary Sources	ESET (2025), Trend Micro (2024), FBI/CISA (2024), UK NCSC (2022), Rapid7 Labs (2026)
Analysis Method	Secondary intelligence synthesis; no direct sample access
TLP Classification	TLP:CLEAR Restricted Distribution
MITRE ATT&CK	T1574.002, T1027, T1055.001, T1562.001, T1140, T1059.003, T1071.001, T1036.005, T1543.003

1. Executive Summary

This report constitutes the analytical continuation of CTI-003 (SparrowDoor Legacy Variant, March 16, 2026), addressing the three unresolved questions documented in Sections 7.3 and 10 of that report: the technical character of the modular SparrowDoor variant deployed in 2024, the persistence of CTI-003's [PHIM] findings across variant generations, and the strategic implications of the architectural evolution for China's collection posture in a post-February 28, 2026 environment.

No sample was available for direct analysis. All technical findings in Sections 3 and 4 are derived from external vendor reporting primarily ESET (March 2025), supplemented by Trend Micro (November 2024), Trustwave SpiderLabs (December 2024), and FBI/CISA joint advisories (2024). This is explicitly a secondary analysis report. All claims are attributed. No finding is labeled [PHIM] in this report, as original sample-level analysis was not conducted.

The July 2024 campaign disclosed by ESET confirms three conclusions. First, FamousSparrow was not dormant between 2022 and 2024 it was actively developing its toolset in a period of deliberate operational silence. Second, the modular variant represents a qualitative architectural shift: from a single-stage sequential loader to a plugin-based, parallelized, memory-resident backdoor that receives capability expansion at runtime from the C2. Third, the first documented use of ShadowPad a privately sold backdoor known to be supplied exclusively to PRC-aligned threat actors signals either access to a digital quartermaster shared with other China-nexus groups, or a deliberate convergence of tooling as operational tempo increases.

The geopolitical assessment in Section 7 argues that the architectural evolution of SparrowDoor between 2022 and 2024 is not a technical upgrade in isolation. It is preparation. The modular variant's capability to receive plugins at runtime, execute commands in parallel, and maintain no disk-resident Stage 2 payload addresses precisely the detection surface that caused earlier variants to be exposed. An actor that knew its legacy toolset

had been documented by ESET in 2021, UK NCSC in 2022 and chose to rebuild rather than retire the family, is an actor with long-term infrastructure investment in a collection mission it has not abandoned.

The CTI-003 closing thesis held that FamousSparrow's pivot to US domestic telecommunications answered a changed intelligence question: not the speed of MENA normalization, but the coordination architecture of a US military response in the Taiwan Strait scenario. The July 2024 campaign targeting a US financial sector trade group and a Mexican research institute is consistent with that thesis. Neither target is a telecom provider. Both are nodes in the economic and policy infrastructure adjacent to the financial mechanisms that would be activated in a large-scale confrontation scenario. The collection question has not narrowed. It has broadened.

2. Methodology

2.1 Scope and Objectives

This report set out to accomplish three objectives: (1) document the technical characteristics of the SparrowDoor modular variant (2024) from external vendor reporting, in the absence of direct sample access; (2) assess the continuity or divergence of CTI-003's [PHIM] findings across the legacy-to-modular evolution; and (3) update the strategic assessment from CTI-003 Section 9 in light of the February 28, 2026 strikes on Iran and subsequent structural changes to the regional environment.

2.2 Secondary Analysis External Intelligence

Primary technical source: ESET Research (March 26, 2025) 'You will always remember this as the day you finally caught FamousSparrow' (WeLiveSecurity). Secondary sources: Trend Micro Earth Estries analysis (November 2024), Trustwave SpiderLabs FamousSparrow report (December 2024), UK NCSC Malware Analysis Report: SparrowDoor (February 2022), Microsoft Salt Typhoon threat actor profile (2024), FBI/CISA joint advisory (2024), Wall Street Journal Salt Typhoon reporting (September 2024). Geopolitical context sourced from Reuters, AP, Arms Control Association, Oman FM public statements, and SerapHim CTI-003 (March 16, 2026).

2.3 Analytical Limitation No Direct Sample Access

All technical findings in this report are derived from external reporting. No binary was analyzed directly. Claims about specific memory addresses, entropy values, opcode patterns, or exact implementation details cannot be independently confirmed without sample access. This report treats external vendor findings as credible but explicitly attributed, not as independently verified. Where CTI-003 [PHIM] findings are assessed against the modular variant, the assessment is based on architectural inference from published descriptions, not direct comparison.

2.4 Confidence Level Scale

Level	Definition
HIGH	Supported by direct technical evidence or corroborated open source reporting
MODERATE	Supported by circumstantial evidence or pattern correlation
LOW	Inferred from limited indicators requires additional evidence to confirm

3. Technical Analysis Modular Variant (2024)

The following findings (M1-M14) are derived entirely from ESET (2025) and supplementary vendor sources. All findings represent secondary analysis. No original analysis was conducted against a sample.

3.1 Campaign Overview and Initial Access

M1 Campaign Scope and Timeline

ESET identified suspicious activity on the network of a US-based financial sector trade group in July 2024. Investigation confirmed FamousSparrow intrusion. A research institute in Mexico was breached within days of the US compromise. A governmental institution in Honduras was identified as an additional victim during the 2022-2024 period. Attribution to FamousSparrow is assessed HIGH by ESET based on SparrowDoor exclusivity, loader code overlaps with documented samples, and reflective loader shellcode matching the UK NCSC 2022 sample.

M2 Initial Access: IIS Webshell via Outdated Exchange / Windows Server

Initial access was achieved via webshell deployment on an IIS server. Both victims were running outdated versions of Windows Server and Microsoft Exchange. The exact exploit used was not determined by ESET. The webshell is AES-encrypted with a hardcoded key and operates as a generic ASP.NET ASHX module, placing it in the DotNetNuke installation directory to blend with legitimate application infrastructure. Subsequent activity used legitimate Windows tools for host and Active Directory enumeration, PowerHub for post-exploitation, and BadPotato for privilege escalation to SYSTEM.

This initial access pattern IIS webshell, outdated Exchange, privilege escalation via public exploit is consistent with the 2021 ProxyLogon exploitation documented in CTI-003 Section 8.5. The +1 day exploitation behavioral signature hypothesized in CTI-003 cannot be confirmed or denied from available reporting on this campaign, as the specific CVE exploited was not disclosed.

3.2 Loader Evolution

M3 Trident Loader: Continuity from Legacy

The loading mechanism uses the same trident loader architecture as the legacy variant documented in CTI-003 and the UK NCSC 2022 report. The legitimate executable used for DLL sideloading is K7AVMScn.exe a K7 AntiVirus Messenger Scanner component. The malicious DLL is K7AVWScn.dll and the encrypted payload is K7AVWScn.doc. This is a direct evolution of the K7UI.dll masquerade documented in CTI-003 F2, now using a different K7 component but maintaining the same regional masquerade logic.

M4 Encryption Upgrade: XOR to RC4

The legacy variant used XOR encryption for the payload file, with the key hH7@83#mi documented by UK NCSC. The modular variant uses RC4 encryption, with the key hardcoded in both the loader and the resulting decrypted payload. RC4 provides stronger obfuscation than XOR against simple byte-frequency analysis, while retaining the symmetric key architecture. The configuration still occupies the last 202 bytes of the encrypted payload file identical in position to the legacy variant's structure.

The substitution table system documented in CTI-003 F12-F15 [PHIM] the three-table character normalization triplet for case-insensitive command processing without Windows API calls is not referenced in ESET 2025 or any other vendor analysis of the modular variant. Its presence or absence in the modular variant cannot be confirmed from available reporting. The XOR-to-RC4 encryption upgrade does not address the same function as the substitution tables, which operated on command string normalization rather than payload encryption. The two mechanisms are architecturally independent. If the substitution tables were present in the legacy variant for import-evasion purposes, the same engineering motivation would apply to the modular variant.

CONFIDENCE: MODERATE Substitution table continuity unresolved without direct sample analysis.

3.3 SparrowDoor Modular Architecture

M5 Two Variants Deployed in a Single Campaign

ESET documented two previously undocumented SparrowDoor versions in the July 2024 campaign. Variant A resembles CrowDoor, a backdoor attributed to Earth Estries by Trend Micro in November 2024. Variant B is the modular version and represents the most significant architectural departure from legacy SparrowDoor. Both variants implement parallelization of commands the most significant change from the legacy sequential architecture.

M6 Parallelization of Commands

In the legacy variant analyzed in CTI-003, commands were processed sequentially. The modular variant implements parallel command execution: when a time-consuming command (file I/O, interactive shell) is received, a new thread is spawned that initiates a separate connection to the C2 server. The unique victim ID and a command ID are sent over the new connection, allowing the C2 to track which connections belong to the same victim and their purposes. Each thread handles a specific set of subcommands independently, while the main command loop continues accepting new instructions.

This architectural change has a direct operational implication. The legacy variant's sequential processing meant a long-running task (file exfiltration, interactive shell session) would block all other command processing. The modular variant eliminates this bottleneck an operator can run an interactive shell, exfiltrate files, and enumerate network configuration simultaneously on the same victim without queuing.

M7 Persistence Mechanism

The modular variant establishes persistence via a service named K7Soft set to run automatically on startup. If service creation fails, a registry Run key with the same name is used. In both cases, the persistence mechanism

executes the backdoor with command line argument 11, which triggers process hollowing of colorcpl.exe (Windows Color Management Tool). Main backdoor operation requires argument 22. This three-mode execution architecture no argument (persistence setup), 11 (hollow and inject), 22 (main operation) provides a clean separation of initialization and operational phases.

M8 Registry Victim Identifier

The modular variant derives a victim identifier from the machine's performance counter and stores it at HKLM\Software\CLASSES\CLSID\ID a nonstandard registry path. Any key under Software\Classes\CLSID\ with a name that is not a valid GUID (formatted as {xxxxxxxx-xxxx-xxxx-xxxx-xxxxxxxxxxxx}) is anomalous. This nonstandard key name is a detection opportunity noted by ESET.

M9 Plugin System: Runtime Capability Expansion

Variant B implements a full plugin architecture. The backdoor can receive new plugins from the C2 at runtime. Plugins are loaded entirely in memory and are not written to disk as standalone files. This is a direct extension of the Stage 2 memory-resident architecture documented in CTI-003 F7 (reflective loading), now applied to operational capability rather than just the primary payload. The disk footprint of the modular variant is further reduced relative to the legacy variant: Stage 2 never appeared on disk during execution in the legacy architecture; the modular variant's plugin extensions never appear on disk at all.

M10 Command Set Expansion

The modular variant supports a command set that includes all legacy capabilities plus additions: interactive shell (parallel), file I/O (parallel), proxy, drive enumeration, file listing, directory creation, file move/rename/delete, C2 configuration change, service/registry reinstallation, and process hollowing restart. The interactive shell spawns cmd.exe and relays I/O via named pipes. The proxy command capability suggests use as a network pivot node, not only as a collection endpoint.

M11 ShadowPad: First Documented Use

The July 2024 campaign is the first documented instance of FamousSparrow deploying ShadowPad. ShadowPad is a privately sold modular RAT known to be supplied exclusively to PRC-aligned threat actors. It was loaded via DLL sideloading using a renamed Microsoft Office IME executable. ShadowPad's inclusion alongside two new SparrowDoor variants suggests either: (A) access to a digital quartermaster shared with APT41 and other China-nexus groups the explanation ESET assesses as most probable for the observed FamousSparrow-Earth Estries-GhostEmperor overlaps; or (B) direct tooling transfer from another PRC-attributed group as operational requirements expanded.

CONFIDENCE: HIGH (ShadowPad deployment confirmed by ESET). MODERATE (quartermaster vs direct transfer cannot discriminate from available reporting).

4. CTI-003 Finding Continuity Assessment

This section assesses the four [PHIM] findings from CTI-003 findings not documented in prior vendor reporting at the time of CTI-003 publication against available information about the modular variant. The purpose is to determine whether these findings represent idiosyncrasies of the specific legacy sample or persistent architectural choices across FamousSparrow development.

CTI-003 Finding	Legacy (CTI-003)	Modular (CTI-004 Assessment)	Status	Confidence
F20 Inverted anti-sandbox	Terminates if IsDebuggerPresent == 0; runs normally under debugger	Not referenced in ESET 2025. ESET notes improved code quality. Architectural motivation persists.	UNRESOLVED	LOW
F12-F15 Substitution table triplet	Three-table normalization system in .rdata; no Windows string API calls	Not referenced in any modular variant reporting. XOR replaced by RC4 independent mechanism.	UNRESOLVED	MODERATE
F16 113 indirect call sites	113 FF 15 sites in 26KB binary; masks runtime API call pattern	Not enumerated in external reporting. Architecture motivating high indirect call density	LIKELY PRESENT MODIFIED	MODERATE

		(import evasion) remains present.		
F11 .text entropy anomaly (6.59)	Elevated entropy indicating code obfuscation	Not enumerated in external reporting. RC4 encryption upgrade suggests continued obfuscation investment.	LIKELY PRESENT MODIFIED	MODERATE

The ESET 2025 analysis confirms significant code overlaps between legacy and modular variants at the loader level, and states the modular variant 'can still be traced back directly to earlier, publicly documented versions.' This continuity of code at the loader level makes it probable that engineering decisions present in the legacy variant particularly deliberate import-evasion architecture were preserved where they remained effective. The XOR-to-RC4 upgrade is an example of a decision that was changed; the substitution table system and indirect call architecture address a different detection surface and may have been retained unchanged. This cannot be confirmed without sample access.

The inverted anti-sandbox logic (CTI-003 F20) is the most uncertain of the four. ESET's characterization of 'marked progress in code quality' could indicate a rewrite of the anti-analysis section, removal of the dead-code hypothesis (CTI-003 F20 Hypothesis B), or retention of the technique in refined form. Any of these outcomes is consistent with ESET's description. The technique is architecturally clever and addresses a detection surface automated sandboxes that has not become less relevant between 2022 and 2024. Removal would be a deliberate decision.

CONFIDENCE: MODERATE overall. Individual finding assessments as noted in the table above. Direct sample analysis of the modular variant is required to resolve all four.

5. Indicators of Compromise

5.1 File Indicators (External Reporting)

Type	Indicator	Notes
File	K7AVMScn.exe	Legitimate K7 AV Messenger Scanner DLL sideloading host
File	K7AVWScn.dll	Malicious loader DLL modular variant
File	K7AVWScn.doc	Encrypted payload RC4, key hardcoded in loader
File	K7UI.dll (legacy)	Stage 1 loader legacy variant (CTI-003, SHA256: 8dfaa1f579...)
Registry	HKLM\Software\CLASSES\CLSID\ID	Nonstandard victim identifier detection opportunity
Service	K7Soft	Persistence service name
Process	colorcpl.exe (hollowed)	Process hollowing target argument 11 execution mode
Named pipe	\\.\pipe\id1<address>	Interactive shell STDOUT/STDERR relay
Named pipe	\\.\pipe\id2<address>	Interactive shell command input relay
Encryption	RC4 (key hardcoded)	Payload encryption replaces XOR key hH7@83#mi (legacy)
Webshell	AES key e2c99096bcecd1b5	Webshell AES key (ESET 2025)
Download srv	43.254.216[.]195	Batch script download server (ESET 2025)

5.2 Network Indicators (External Reporting)

Type	Indicator	Notes

IP	194.165.16[.]69	Legacy SparrowDoor C2 (ESET 2021)
IP	198.12.75[.]112	Legacy SparrowDoor C2 (ESET 2021)
IP	43.254.216[.]195	Modular variant batch script / payload download server (ESET 2025)
Domain	cdn.kkxx888666[.]com	DRBControl overlap Metasploit C2 on FamousSparrow victim (legacy)
Protocol	HTTPS port 443	C2 communication both legacy and modular variants
Protocol	Three C2 server pairs	Modular variant config: three address/port pairs with sleep-and-retry

5.3 Behavioral Indicators

Type	Indicator	Notes
Anti-sandbox [CTI-003 PHIM]	Terminates if IsDebuggerPresent == 0	Legacy variant modular status unresolved (Section 4)
Substitution tables [CTI-003 PHIM]	.rdata pattern at 0x10008898, 0x10008ea1, 0x10009021	Legacy variant YARA candidate modular status unresolved
Parallelization	New socket + thread per time-consuming command	Modular variant not present in legacy
Plugin loading	Plugins received from C2 at runtime; loaded in memory only	Modular Variant B no disk artifact
DLL sideloading	K7 component masquerade (K7AVMScn / K7AVWScn naming)	Modular variant evolution of K7UI masquerade (CTI-003 F2)
Process hollowing	colorcpl.exe hollowed via argument 11	Modular variant (ESET 2025)
ShadowPad	Loaded via renamed Microsoft Office IME executable	First documented FamousSparrow use (ESET 2025)

6. MITRE ATT&CK Mapping

ID	Technique	Observed
T1574.002	DLL Side-Loading	K7AVMScn.exe / K7AVWScn.dll masquerade; ShadowPad via Office IME
T1027	Obfuscated Files or Information	RC4 payload encryption; in-memory plugin loading
T1055.012	Process Injection: Process Hollowing	colorcpl.exe hollowed (argument 11 execution mode)
T1562.001	Impair Defenses: Disable or Modify Tools	Anti-sandbox logic legacy (CTI-003 F20); modular status unresolved
T1140	Deobfuscate / Decode Files or Information	RC4 decryption of payload and C2 configuration at runtime
T1059.003	Command Interpreter: Windows Command Shell	cmd.exe spawned via interactive shell command
T1071.001	Application Layer Protocol: Web Protocols	HTTPS C2 on port 443
T1543.003	Create or Modify System Process	K7Soft service for persistence

T1036.005	Masquerading: Match Legitimate Name	K7 AV component naming; colorcpl.exe process hollowing
T1090	Proxy	Proxy command capability network pivot use
T1056.001	Input Capture: Keylogging	Plugin capability (external reporting)
T1113	Screen Capture	Plugin capability (external reporting)

7. Geopolitical Strategic Assessment

This section constitutes strategic assessment, clearly separated from the technical findings above. All conclusions carry explicitly stated confidence levels and represent analytical judgment, not confirmed fact. This section updates the CTI-003 Section 9 assessment in light of subsequent events, specifically the February 28, 2026 US-Israel strikes on Iran and their structural consequences.

7.1 The Operational Silence as Evidence

FamousSparrow was believed dormant between 2022 and 2024. ESET's July 2024 discovery established it was not dormant it was developing. The operational silence corresponded precisely to the period in which: (1) the legacy toolset had been publicly documented (ESET 2021, UK NCSC 2022); (2) MENA normalization was disrupted by October 7, 2023, temporarily reducing the urgency of collection against that question; and (3) the decision to rebuild SparrowDoor into a modular architecture was implemented.

An actor that voluntarily goes dark after its toolset is exposed, rebuilds the toolset with significant architectural improvements, and resurfaces against new target categories is an actor with institutional continuity, development resources, and a long-term collection mandate. The two-year silence is not evidence of reduced activity. It is evidence of a development cycle.

CONFIDENCE: HIGH (timeline facts confirmed by ESET). MODERATE (operational intent interpretation inferred from pattern, not recovered communications).

7.2 Target Selection: Financial and Research Infrastructure

The July 2024 targets a US financial sector trade group and a Mexican research institute differ from the telecom and ISP targeting documented in FBI/CISA 2024 advisories and from the hotel diplomatic zone targeting documented in CTI-003. This diversification is significant.

A financial sector trade group is a node in the institutional architecture that connects government economic policy, regulatory frameworks, and private sector financial coordination. In the context of the Taiwan Strait scenario assessed in CTI-003 Section 9.3, this target category has direct relevance: sanctions architecture, financial coordination mechanisms, and the economic response infrastructure to a large-scale confrontation would all pass through institutions of this type. The target is not telecom infrastructure. It is the policy and coordination layer above telecom infrastructure.

The Mexican research institute target expands the geographic scope beyond US domestic infrastructure. Mexico is a significant US economic partner and a node in supply chain and trade policy that would be directly relevant to any large-scale economic confrontation scenario. The breach occurring days before the US compromise suggests a sequenced operation, not an opportunistic parallel compromise.

CONFIDENCE: MODERATE Target category analysis is inferential. Direct intelligence objectives for the specific victims were not disclosed in available reporting.

7.3 Post-February 28 Strategic Update

CTI-003 Section 9.3 assessed that the MENA normalization architecture was close enough to operational completion to no longer be disruptable by Iran's proxy network. The February 28, 2026 strikes confirmed this assessment in its most direct form: Iran's supreme leadership was killed in the opening wave, its intelligence apparatus was operationally blinded by precision targeting of its senior intelligence leadership, and Iraq's active role in the operation shooting down Iranian drones near Baghdad Airport demonstrated the completion of the realignment that Dust Specter (CTI-002) was designed to detect.

The structural consequences for China's collection posture are direct. The strategic question that motivated FamousSparrow's MENA hotel infrastructure how fast is normalization progressing, and is proxy disruption still viable has been answered definitively. The answer is that it was not viable. The Iran buffer is eliminated. The Malacca Dilemma's overland alternative is closed. The Taiwan Strait confrontation scenario, which motivated the

2023 pivot to US domestic telecom infrastructure, is now the primary scenario without the MENA variable as a complicating or compensating factor.

FamousSparrow's modular variant more capable, more evasive, architecturally capable of receiving expanded capabilities at runtime without exposing new disk artifacts is better suited to long-term persistence in high-value targets than the legacy variant. An operation building the sensor layer for a Taiwan Strait scenario needs persistence measured in months or years, not days. The architectural upgrade is consistent with that requirement.

CONFIDENCE: MODERATE Strategic consequence assessment is inferential from structural outcomes. No recovered intelligence products directly link FamousSparrow collection to Taiwan Strait planning.

7.4 Attribution Cluster Dispute: FamousSparrow vs Salt Typhoon

Microsoft's attribution of FamousSparrow, GhostEmperor, and Earth Estries to a single Salt Typhoon cluster conflicts with ESET's assessment. ESET tracks FamousSparrow as a distinct group with loose links to the others, explaining observed overlaps via a digital quartermaster hypothesis rather than cluster conflation. CTI-003 adopted the Microsoft assessment. This report revises that position.

The digital quartermaster hypothesis is analytically more coherent for two reasons. First, SparrowDoor is exclusive to FamousSparrow across all documented reporting no other group has been observed using it. A shared toolset would be expected if these were the same actor or closely coordinated teams, but SparrowDoor's exclusivity suggests a distinct development team with its own tooling investment. Second, the code overlaps between SparrowDoor and Earth Estries' HemiGate/CrowDoor documented by ESET are consistent with shared components from a quartermaster a common cryptographic library, a shared loader framework, reused utility code rather than the same actor deploying different names for the same operation.

This report adopts the ESET assessment: FamousSparrow is a distinct cluster with loose quartermaster-mediated links to Earth Estries. The Salt Typhoon label as applied by Microsoft should be understood as an analytical convenience rather than a confirmed operational cluster boundary.

CONFIDENCE: MODERATE Cluster boundary assessment remains contested. Insufficient technical detail from Microsoft's attribution to independently evaluate.

7.5 Doctrinal Convergence: BPFdoor / Red Menshen and the Passive Implant Doctrine

On March 26, 2026 ten days after CTI-003 publication Rapid7 Labs released 'Sleeper Cells in the Telecom Backbone,' documenting a sustained espionage campaign by Red Menshen (also tracked as Earth Bluecrow, DecisiveArchitect, Red Dev 18), a China-nexus threat actor active against telecom providers in the Middle East and Asia since at least 2021. The central tool is BPFdoor, a Linux kernel-level backdoor that installs a Berkeley Packet Filter inside the kernel, inspecting incoming traffic for a predefined magic packet without opening listening ports or generating beaconing activity.

BPFdoor and SparrowDoor are distinct tools deployed by distinct actors. The convergence documented here is not attribution overlap it is doctrinal. Both tools embody the same engineering philosophy, which this report designates the passive implant doctrine: design for persistence over activity, minimize the static and behavioral detection surface to near-zero, and activate only on operator demand. The architectural implementations differ at every level BPFdoor operates in kernel space on Linux, SparrowDoor operates in user space on Windows but the strategic logic is identical.

Dimension	SparrowDoor (FamousSparrow)	BPFdoor (Red Menshen)
Detection surface	Minimal IAT (KERNEL32 only); 113 indirect call sites mask runtime capability [CTI-003 F16]	No listening port; no beaconing; BPF filter operates inside kernel before user-space visibility
Activation model	Stage 2 loaded from disk on operator command; plugin system receives capability at runtime	Magic packet trigger activates remote shell; controller operated from within victim network
Masquerade	K7 Antivirus component identity at export table level; MpSvc.dll at string level [CTI-003 F2-F3]	Mimics HPE ProLiant bare-metal services and Docker container components to blend into telecom hardware
Persistence target	Hotel management systems, Exchange servers, US telecom ISPs Windows environments	Linux telecom backbone routers, SCTP signaling systems, 4G/5G core components

Trigger camouflage	C2 over HTTPS port 443; XOR/RC4 encrypted communications	New variant: trigger hidden inside legitimate HTTPS traffic at fixed byte offset; ICMP for inter-host communication

The most significant technical development in the new BPFdoor variant documented by Rapid7 is the concealment of the activation trigger inside legitimate HTTPS traffic, with the magic packet marker fixed at a specific byte offset within the inspected data structure. This is a direct parallel to SparrowDoor's substitution table system [CTI-003 F12-F15]: both techniques address the same problem how to communicate with an implant without generating a detectable pattern through different implementations. SparrowDoor normalizes operator commands to avoid API call signatures; BPFdoor embeds its activation signal inside traffic that passes through proxies, load balancers, and firewalls without modification.

Rapid7 VP of Cyber Intelligence Christiaan Beek stated that the strongest evidence points to intelligence collection and long-term access, not immediate disruption and that in telecom networks, this means visibility into signaling systems, subscriber-related data, communications metadata, and other high-value infrastructure functions. This statement is a direct external confirmation of the CTI-003 Section 9.3 thesis. The intelligence question both operations are positioned to answer is the same: what does communication infrastructure look like at the backbone level, and how does it change when a confrontation scenario activates? BPFdoor answers it from inside the Linux telecom backbone. SparrowDoor modular variant answers it from inside enterprise and ISP Windows environments. The two tools are complementary in coverage, not competitive. Signaling infrastructure the layer Beek specifically names is not incidental to military coordination. It is the substrate through which coordination occurs.

Rapid7 explicitly notes similarities to Volt Typhoon and Salt Typhoon campaigns, while observing that the mechanisms have evolved and the strategic objectives have a longer tail. The Volt Typhoon framing is significant: Rapid7 characterizes that campaign specifically as preparation for a diversionary attack if the PRC engaged in military actions against Taiwan. This is the only explicit Taiwan reference in the Rapid7 reporting, and it confirms from an independent vendor the same strategic framing that CTI-003 Section 9.4b argued for FamousSparrow's 2023 US telecom pivot. CTI-003 inferred the Taiwan Strait pre-positioning thesis from targeting sequence analysis and geopolitical correlation. Rapid7 states it directly for Volt Typhoon. The doctrinal group FamousSparrow, Red Menshen, Volt Typhoon is now confirmed by external reporting to share not only methods but strategic objective: pre-positioning for a Taiwan contingency. The longer tail Rapid7 describes is not a metaphor. It is the distance between now and the activation event.

Rapid7's characterization of the strategic objectives as having a longer tail is, taken precisely, an external confirmation of CTI-003's closing thesis. That thesis held that FamousSparrow's 26KB legacy loader was an artifact from the beginning of a trajectory that the collection infrastructure built into US telecom networks would be more relevant to what comes after the Middle East is settled than to any intelligence produced against hotel corridors in Riyadh. The post-February 28 environment has accelerated that trajectory. The Iran buffer is gone. The Taiwan Strait scenario is no longer one of several contingencies competing for collection priority. It is the primary scenario. The longer tail Rapid7 identifies is now shorter than it was when CTI-003 was written.

One gap in the current CTI-004 analysis requires noting. Beek specifically identifies exposed edge devices, containerized environments, and signaling-related traffic as the priority defensive surface the same environments BPFdoor targets by masquerading as Docker container components and HPE ProLiant bare-metal services. SparrowDoor's current masquerade is K7 Antivirus a Windows enterprise security product with no footprint in Linux telecom backbone environments. If FamousSparrow's collection mandate expands from Windows ISP/enterprise environments to Linux telecom backbone infrastructure, the K7 masquerade will not survive contact with that environment. The architectural question this raises whether FamousSparrow will develop a Linux-capable variant with environment-appropriate masquerade, or whether Red Menshen already serves that function as a complementary actor is unresolved from available reporting and represents a productive hypothesis for future analysis.

CONFIDENCE: HIGH (BPFdoor campaign facts and Beek statements confirmed by Rapid7 Labs / Cybersecurity Dive, March 2026). HIGH (Volt Typhoon Taiwan framing confirmed by Rapid7). MODERATE (doctrinal convergence and longer tail argument two independent analytical paths converging on the same conclusion). LOW (FamousSparrow Linux variant hypothesis speculative, no supporting evidence).

8. Pivot Analysis

All pivot work conducted using passive open-source intelligence only. No active probing of infrastructure was performed.

8.1 K7 Masquerade Evolution as Tracking Artifact

CTI-003 Section 8.3 documented the K7UI export pattern (K7UI_1, K7UI_13) as a YARA candidate and hypothesized that FamousSparrow deploys region-adapted masquerade variants K7 naming for Asia/MENA theater, generic FOSS naming (libcurl.dll, libhost.dll) for Western targets. The modular variant's use of K7AVMScn.exe and K7AVWScn.dll a different K7 product but the same vendor and regional logic is consistent with and extends this hypothesis. The K7 masquerade is not a coincidence or a one-time choice. It is a persistent regional targeting decision.

K7 Computing's market penetration remains concentrated in India, Southeast Asia, and a secondary MENA subset. The modular variant's July 2024 US targets were compromised using this regional masquerade naming, which creates an anomaly: the K7 masquerade is regionally plausible for Asia/MENA environments, not for a US financial sector trade group running enterprise security tooling that would not include K7 products. This could indicate: (A) a single toolset deployed across regional and US targets without variant adaptation at the loader level; or (B) the K7 naming serves a different function in US targets not blending with expected security software, but leveraging the absence of K7 in US environments to reduce signature matching against K7-aware detection rules.

CONFIDENCE: MODERATE K7 masquerade persistence confirmed. Hypothesis B (absence-based evasion) is speculative without additional operational context.

8.2 Substitution Table YARA Candidate Cross-Variant Status

CTI-003 Section 8.4 identified the three-table byte sequence beginning at 0x10008898 as a YARA candidate with high specificity, noting that cross-sample search required access to a large malware database not available to SerapHim at the analyst's access level. The modular variant analysis by ESET (2025) does not document the substitution table system. This absence could mean the tables are not present in the modular variant, or that ESET's analysis did not document this specific mechanism. The YARA candidate's value depends on cross-variant persistence. Without sample access to the modular variant, this remains unresolved.

8.3 ShadowPad as Infrastructure Pivot

ShadowPad's introduction creates a new pivot surface. ShadowPad infrastructure has been documented in association with APT41, APT10, and multiple China-nexus groups. C2 infrastructure used for ShadowPad deployments is often shared across campaigns by the same or related actors. If the ShadowPad instance in the July 2024 FamousSparrow campaign used infrastructure overlapping with known ShadowPad clusters, this would provide a pivot path to additional FamousSparrow infrastructure not yet documented. Passive DNS and certificate analysis of ShadowPad C2s from this campaign would be a productive next step with commercial platform access.

8.4 Pivot Summary

Artifact	Type	Tracking Value	Confidence
K7AVMScn / K7AVWScn naming	Code signature	K7 masquerade persistence YARA candidate (evolution of CTI-003 F2)	HIGH
43.254.216[.]195	Network	Download server passive DNS pivot candidate	HIGH
K7Soft service name	Behavioral	Persistence mechanism fingerprint	HIGH
CLSID\ID registry key	Behavioral	Nonstandard victim ID detection and pivot opportunity	HIGH
ShadowPad C2 infrastructure	Network	Cross-group pivot via shared ShadowPad C2 requires commercial access	MODERATE
CTI-003 substitution tables	Code signature	Cross-variant YARA status unresolved modular sample required	MODERATE

9. Variant Comparison: Legacy vs Modular

Attribute	Legacy (CTI-003, 2019-2022)	Modular (CTI-004, 2024)

Architecture	Single-stage loader; Stage 2 from disk	Plugin-based; plugins received from C2 in memory
Command processing	Sequential	Parallel new thread + socket per time-consuming command
Payload encryption	XOR (key: hH7@83#mi)	RC4 (hardcoded per sample)
Masquerade	K7UI.dll (K7UI_1, K7UI_13 exports)	K7AVMScn.exe + K7AVWScn.dll + K7AVWScn.doc
Persistence	Not documented in CTI-003 sample	K7Soft service; fallback to Run registry key
Process injection	Reflective DLL loading of MpSvc.dll	Process hollowing of colorcpl.exe
Anti-sandbox	Inverted IsDebuggerPresent logic [CTI-003 PHIM]	Not documented in external reporting status unresolved
Substitution tables	Three-table normalization system [CTI-003 PHIM]	Not documented in external reporting status unresolved
Additional tooling	None documented	ShadowPad (first use); PowerHub; BadPotato
Code quality	Basic (ESET assessment)	Marked progress (ESET assessment)
Sample analyzed	Yes CTI-003	No CTI-004 secondary analysis only

10. Analysis Limitations

Limitation	Detail
No direct sample access	All technical findings in this report are secondary. No binary was analyzed directly. CTI-003 [PHIM] findings cannot be confirmed or refuted against the modular variant without sample access.
CTI-003 PHIM continuity unresolved	F20 (inverted anti-sandbox), F12-F15 (substitution tables), F16 (indirect call density), and F11 (.text entropy) cannot be assessed against the modular variant from available reporting.
Attribution cluster boundaries	The FamousSparrow / Salt Typhoon / Earth Estries / GhostEmperor cluster boundary dispute is unresolved. This report adopts the ESET distinct-cluster assessment, which may diverge from future definitive attribution findings.
ShadowPad C2 pivot	ShadowPad infrastructure pivot requires commercial platform access (PassiveTotal, Shodan, Censys) not available at the analyst's access level.
Geopolitical assessment	Section 7 connects technical targeting patterns to geopolitical outcomes. Causal confirmation is not possible from open-source analysis. All strategic assessments carry explicitly stated confidence levels.
July 2024 exploit not identified	The specific CVE exploited for initial access in the July 2024 campaign was not disclosed by ESET. The ProxyLogon +1 day behavioral signature hypothesized in CTI-003 Section 8.5 cannot be assessed against this campaign.

11. Defensive Recommendations

#	Recommendation
1	K7 naming pattern monitoring: extend CTI-003 Recommendation 1. Alert on K7AVMScn.exe, K7AVWScn.dll, K7AVWScn.doc loaded from non-standard paths. The K7 masquerade persists across variant generations.

2	Nonstandard CLSID registry key: monitor for registry keys under HKLM\Software\Classes\CLSID\ with names that are not valid GUIDs. This is a specific detection opportunity for the modular variant's victim ID mechanism.
3	K7Soft service detection: alert on service creation with the name K7Soft, particularly when the service binary is not in a K7 Computing installation directory.
4	colorcpl.exe process hollowing: alert on colorcpl.exe (Windows Color Management) being launched with unusual command line arguments or exhibiting network activity. Legitimate colorcpl.exe does not establish outbound connections.
5	Named pipe pattern: alert on named pipes matching the pattern \\.\pipe\id1<address> or \\.\pipe\id2<address> being created by processes not associated with legitimate development or debugging tools.
6	Memory-resident plugin loading: behavioral EDR rules for in-memory module loading from C2 connections particularly PE files received over encrypted channels and loaded without a corresponding disk write event.
7	ShadowPad indicators: apply all published ShadowPad IOCs to FamousSparrow hunting. Shared ShadowPad infrastructure may provide a pivot path to FamousSparrow C2 infrastructure not yet documented in public reporting.
8	Outdated Exchange / Windows Server: the July 2024 initial access relied on outdated Exchange and Windows Server versions. Organizations in financial sector, research, and government should treat unpatched Exchange as a high-priority FamousSparrow exposure. This is the same exploitation surface used in the 2021 ProxyLogon campaign.
9	CTI-003 recommendations remain active: all eight defensive recommendations from CTI-003 apply to the modular variant. Substitution table YARA candidate, sandbox evasion re-analysis guidance, and US telecom context recommendations are not superseded by this report.

12. References

[1] ESET Research. You will always remember this as the day you finally caught FamousSparrow. WeLiveSecurity. March 26, 2025.

[2] ESET Research. FamousSparrow: A suspicious hotel guest. September 2021.

[3] UK NCSC. Malware Analysis Report: SparrowDoor. February 2022.

[4] Trend Micro. Earth Estries Breaking Down Persistent TTPs in Prolonged Cyber Operations. November 2024.

[5] Trustwave SpiderLabs. FamousSparrow / Salt Typhoon report. December 2024.

[6] Microsoft. Salt Typhoon threat actor profile. 2024.

[7] FBI / CISA. Joint advisory on Salt Typhoon / FamousSparrow telecom breaches. 2024.

[8] Wall Street Journal. Salt Typhoon breached multiple US telecommunications providers. September 2024.

[9] Reuters. US and Israel strike Iran; Supreme Leader Khamenei killed. February 28, 2026.

[10] Arms Control Association. US-Iran Geneva negotiations and February 28 strike timeline analysis. March 2026.

[11] CBS Face the Nation. Oman FM Badr Al-Busaidi Geneva talks and post-strike statement. February 27 / March 2026.

[12] SentinelOne. ShadowPad: A Masterpiece of Privately Sold Malware in Chinese Espionage. 2021.

[13] MITRE ATT&CK. FamousSparrow (G1101). attack.mitre.org.

[14] ESET malware-ioc. FamousSparrow sample repository. github.com/eset/malware-ioc/famoussparrow.

[15] SerapHim. CTI-003: FamousSparrow / SparrowDoor Dynamic and Static Analysis of a PRC-Attributed Loader Component with Geopolitical Strategic Assessment. March 16, 2026.

[16] SerapHim. CTI-002: Dust Specter State-Sponsored OSINT Operation Targeting Iraqi Diplomatic Infrastructure. March 10, 2026.

[17] Rapid7 Labs. Sleeper Cells in the Telecom Backbone BPFdoor in Telecom Networks. March 26, 2026.

[18] Cybersecurity Dive / Eric Geller. Espionage campaign targets telecom with stealthy Linux-based backdoor. March 27, 2026.

[19] The Hacker News. China-Linked Red Menshen Uses Stealthy BPFDoor Implants to Spy via Telecom Networks. March 2026.

TLP:CLEAR. This report may be shared freely without restriction. All network indicators have been defanged. SerapHim, Independent Cyber Threat Intelligence, March 2026.